Deep Learning Essentials

CompTIA SecAI+ | Section 2: Introduction to AI Types and Techniques

What Deep Learning Is and Why It Matters for Security

Deep learning is a subset of machine learning that uses artificial neural networks with multiple processing layers. The 'depth' refers to the number of hidden layers between input and output. Where classical machine learning requires feature engineering (humans explicitly defining which characteristics the model should examine), deep learning performs representation learning: it discovers relevant features automatically from raw data through hierarchical abstraction.

For security professionals, deep learning matters because the threats it detects best are exactly those hardest to catch with traditional methods: novel malware variants with no known signatures, subtle anomalies in user behaviour, sophisticated multi-stage attack campaigns embedded in normal-looking traffic, and adversarial inputs crafted to evade conventional filters.

Approach	Feature Engineering	Generalisation to Novel Threats	Interpretability
Rule-based systems	Human-defined rules	None (only known signatures)	High (explicit rules)
Classical ML (SVM, RF)	Human-engineered features	Moderate	Moderate
Shallow neural networks	Partially automated	Better than classical ML	Low
Deep learning (many layers)	Fully automated	High (hierarchical abstraction)	Very low

Neural Network Architecture: Neurons, Layers, and Weights

An artificial neural network consists of interconnected nodes (neurons) organised in layers. The input layer receives raw data. Hidden layers transform the input through weighted linear transformations followed by non-linear activation functions. The output layer produces the final prediction. Each connection has a learned weight that scales the signal passing through it.

During training, backpropagation computes how much each weight contributed to the prediction error (via the chain rule of calculus) and adjusts all weights in the direction that reduces error. This process, repeated across millions of training examples, causes the network to converge on weights that capture useful patterns.

- Activation functions introduce non-linearity, enabling the network to learn complex decision boundaries. Common choices: ReLU, sigmoid, and tanh.
- Dropout regularisation randomly sets a fraction of neuron outputs to zero during training, preventing overfitting and improving generalisation to new threats.
- Batch normalisation stabilises training by normalising layer inputs, accelerating convergence.

- Skip connections (residual connections) allow gradients to flow between non-adjacent layers, enabling very deep networks (50-200+ layers) to train successfully.

Network Component	Function	Security Relevance
Input layer	Receives raw data (pixels, log features, token embeddings)	Data format defines observable threat signals
Hidden layers (deep)	Extract hierarchical features through learned transformations	Deeper layers capture more abstract attack patterns
Output layer	Produces prediction (class, score, or probability)	Determines detection granularity
Weights	Learned parameters encoding discovered patterns	Attack target: data poisoning corrupts weights
Activation functions	Introduce non-linearity enabling complex decision boundaries	Affect adversarial example transferability

Hierarchical Representation Learning

The most important property of deep networks is hierarchical representation learning: lower layers learn simple features, higher layers combine them into increasingly abstract concepts. In malware detection: early layers detect API call patterns; middle layers recognise function-level behaviours; deep layers identify intent (credential harvesting, persistence installation, exfiltration). In network traffic analysis: early layers detect individual packet features; middle layers recognise protocol-level patterns; deep layers identify campaign-level behaviours.

Key Point: Hierarchical abstraction is why deep learning catches unknown malware that shares no code or signature with known samples but exhibits similar high-level behaviours. Signature-based tools operate at the lowest abstraction level; deep learning operates at all levels simultaneously.

Malware Detection: From Signatures to Behavioural Deep Learning

Traditional antivirus relies on byte-level signatures. A single mutation (adding a NOP sled, reordering functions, recompiling) defeats the signature. Deep learning malware detectors analyse raw binary bytes, API call sequences, or dynamic execution traces, learning what malicious code does rather than what it looks like.

Endgame (now Elastic) pioneered byte-level deep learning malware detection using a CNN-based model (MalConv) processing raw PE file bytes without feature engineering. Cylance (now BlackBerry Cylance) commercialised deep learning malware prevention in endpoint security. Both demonstrated generalisation to malware variants sharing zero code with training samples.

Real-World Incident - Lazarus Group Operation AppleJeus (2018-present): The North Korean threat actor Lazarus Group continuously evolves cryptocurrency-targeting malware by modifying code structure while preserving functional behaviour. Signature-based AV consistently failed to detect new variants. Deep learning models trained on API call sequences maintained high detection rates across variants because the high-level behavioural signature (cryptocurrency wallet access, credential exfiltration) remained stable

despite code-level evolution.

Deep Learning for Network Traffic Analysis

Network traffic has complex temporal and multi-dimensional structure that deep learning handles well. Recurrent architectures (LSTM, GRU) or transformers model packet timing sequences. CNNs extract local patterns in packet payloads. Autoencoders learn compressed representations of normal traffic and flag deviations as anomalies, requiring only examples of normal traffic for training.

Advanced Persistent Threats deliberately use legitimate protocols (HTTPS, DNS, SMTP) to blend with normal traffic. Deep learning models trained on normal traffic behaviour learn organisation-specific baselines and identify when legitimate-looking traffic deviates in ways consistent with data exfiltration or C2 communication.

Architecture	Best For	Security Application
CNN (Convolutional)	Local pattern extraction in fixed-size windows	Packet payload analysis, malware byte-level detection
LSTM/GRU (Recurrent)	Long-sequence temporal dependencies	Network flow analysis, user session modelling
Autoencoder	Learning normal data distribution unsupervised	Anomaly detection without labelled attack data
Transformer	Parallel processing with global attention	Log analysis, threat intelligence NLP, code scanning
GAN (Generative Adversarial)	Generating realistic examples of both classes	Synthetic attack data generation, adversarial training

User Behaviour Analytics (UBA) with Deep Learning

User Behaviour Analytics applies deep learning to detect compromised accounts and insider threats by modelling normal user behaviour at fine granularity. Key dimensions include: file access patterns (which files, at what times, with what frequency); authentication location and device fingerprint sequences; email and communication patterns; application usage correlated with calendar events; and data transfer volumes correlated with business processes. Sophisticated insider threats and compromised credentials often show anomalies only when multiple dimensions are considered jointly.

Real-World Incident - Capital One Data Breach (2019): A former AWS employee exploited a misconfigured WAF to extract data on over 100 million customers via SSRF and S3 API calls. Post-incident analysis showed the attacker's pattern - high-volume S3 GetObject calls from an unusual source IP at an unusual time on resources never previously accessed - would have been highly anomalous to a well-trained UBA deep learning model. The breach prompted adoption of behavioural anomaly detection for cloud API activity across major financial institutions.

Adversarial Attacks on Deep Learning Systems

Adversarial attacks exploit how deep neural networks learn decision boundaries. Small perturbations to an input can cross the boundary without appearing to change the input meaningfully. In security contexts: an attacker can modify malware binaries by adding dead code that shifts the model's representation of the file to the benign side of the boundary. This evasion can be computed analytically with model access (white-box) or estimated through repeated queries (black-box).

Attack Type	Attacker Knowledge Required	Typical Use Against Security Models	Defence
White-box (FGSM, C&W)	Full model access (weights, architecture)	Adversarial malware crafted to evade specific detector	Adversarial training, model ensembling
Black-box (query-based)	API access only, no model weights	Iterative malware mutation to evade deployed classifier	Rate limiting, query monitoring
Transfer attack	Access to a surrogate model	Craft adversarial examples on open model, transfer to target	Model diversity, proprietary architectures
Physical adversarial	Ability to modify physical objects	Adversarial patches to fool security cameras	Ensemble models, input preprocessing

The Explainability Problem in Deep Learning Security

Neural networks with millions of parameters produce predictions through a complex series of matrix operations that do not translate to human-interpretable explanations. In security operations: analysts cannot validate why an alert was raised; incident responders cannot explain decisions to stakeholders; regulators in financial, healthcare, and critical infrastructure sectors may require explainable decision-making for automated actions.

Key explainability techniques: SHAP (SHapley Additive exPlanations), assigning each input feature a contribution value for a specific prediction; LIME (Local Interpretable Model-agnostic Explanations), approximating the model locally with an interpretable surrogate; attention visualisation highlighting influential input tokens; and saliency maps highlighting input regions most influential to the prediction.

Pre-trained Models, Transfer Learning, and Fine-tuning

Training a large deep learning model from scratch requires massive labelled datasets and weeks of GPU compute. Transfer learning resolves this: start with a model pre-trained on a large general dataset and fine-tune it on a smaller domain-specific dataset. A transformer pre-trained on internet text is fine-tuned on threat intelligence reports to extract IOCs; a CNN pre-trained on ImageNet is fine-tuned on security camera footage to detect weapons.

Fine-tuned models inherit both the strengths and the learned biases of the base model. A base model trained on English-dominant text may underperform on threat reports in other languages. Security teams should evaluate fine-tuned model performance specifically in their deployment domain.

Deep Learning Frameworks and Security Tooling

Framework / Tool	Type	Security Use Cases
TensorFlow (Google)	General deep learning framework	Custom threat detection models, NLP, image security
PyTorch (Meta)	General deep learning framework	Research-grade security ML, adversarial robustness testing
Keras	High-level API on TensorFlow	Rapid prototyping of security classifiers
Hugging Face Transformers	Pre-trained model hub + fine-tuning library	NLP security: phishing detection, threat intelligence
MalConv / Ember	Malware-specific deep learning models	Byte-level malware detection without feature engineering
Adversarial Robustness Toolbox (IBM)	Adversarial ML testing library	Generating adversarial examples, testing model robustness

Key Terms Glossary

Term	Definition
Deep learning	Machine learning using multi-layer neural networks enabling hierarchical representation learning
Neural network	Computational model of interconnected neurons organised in layers, inspired by biological brain structure
Backpropagation	Algorithm computing gradients of network weights with respect to prediction error, enabling training via gradient descent
Activation function	Non-linear function applied to neuron outputs (ReLU, sigmoid) enabling complex decision boundaries
Dropout	Regularisation technique randomly disabling neurons during training to prevent overfitting
Representation learning	Deep learning's automatic discovery of useful features from raw data, eliminating manual feature engineering
Transfer learning	Using a model pre-trained on a large dataset as starting point for training on a smaller domain-specific dataset
Autoencoder	Neural network trained to compress and reconstruct input data, used for anomaly detection
Adversarial example	Input with imperceptible perturbations crafted to cause a deep learning model to misclassify it
FGSM	Fast Gradient Sign Method - white-box adversarial attack that perturbs input to maximally increase loss
Black box attack	Adversarial attack conducted without model weight access, using only observable outputs to guide perturbation
Explainability (XAI)	Techniques producing human-interpretable explanations for deep learning predictions (SHAP, LIME, attention visualisation)
Data poisoning	Corrupting training data to embed backdoors or degrade model performance on targeted inputs

UBA	User Behaviour Analytics - deep learning systems modelling normal user activity and flagging deviations

Quick Revision Checklist

- Deep learning uses multi-layer neural networks to learn hierarchical representations automatically from raw data
- Earlier layers detect simple features; deeper layers combine them into progressively abstract concepts
- Backpropagation computes weight gradients enabling iterative training to minimise prediction error
- Deep learning detects novel threats by learning malicious intent patterns, not just known signatures
- Key security applications: malware detection, network anomaly detection, UBA, NLP threat intelligence, image security
- Adversarial examples exploit decision boundary geometry to evade detection with imperceptible input changes
- White-box attacks (FGSM, C&W) require model access; black-box attacks use only API query outputs
- The black box problem requires explainability techniques (SHAP, LIME) for regulatory compliance and analyst trust
- Transfer learning enables deployment of powerful deep models without large labelled datasets
- Fine-tuned models inherit base model biases - always evaluate performance in the target deployment domain
- Capital One (2019) demonstrated the value of deep learning UBA for detecting unusual cloud API access patterns
- Lazarus Group / AppleJeus demonstrated deep learning's ability to detect evolving malware across code variants

20 Exam-Based MCQs — Deep Learning Essentials

Test yourself after reading. These questions are written in real exam style — scenario-heavy, with plausible distractors. Read every explanation, including for questions you answered correctly.

Q1. ***Scenario:*** *A CISO evaluates two endpoint security platforms. Platform A uses signatures with 99.9% detection on known malware. Platform B uses deep learning with 99% on the same benchmark. The CISO's main concern is protection against malware developed specifically to evade existing detection.* A security vendor claims their deep learning malware detector achieves 99% accuracy on their benchmark dataset of known malware. A security architect says this metric is insufficient. Which additional criterion is MOST critical for assessing the detector's ability to protect against emerging threats?

A. The model's inference latency on a single CPU core

B. The model's detection rate on malware variants with zero code overlap to training samples

C. The number of training examples used to achieve 99% benchmark accuracy

D. Whether the model supports batch processing for offline scanning

Answer: B **Explanation:** The critical capability is generalisation to novel variants - unknown malware

sharing no code with training samples but exhibiting similar behavioural patterns. A benchmark of known malware only measures memorisation. A and D are operational metrics. C is relevant to training quality but does not directly measure generalisation.

Q2. Which component of a neural network enables it to learn non-linear decision boundaries, making it capable of distinguishing complex attack patterns from benign activity?

A. The input normalisation layer that scales feature values to the same range

B. The dropout layer that randomly disables neurons during training

C. Non-linear activation functions applied to neuron outputs at each layer

D. The learning rate scheduler that adjusts weight update step sizes

Answer: C **Explanation:** Without non-linear activation functions, a neural network regardless of depth would be mathematically equivalent to a single linear transformation - incapable of learning the complex boundaries separating malware from benign code. A addresses data scaling. B addresses regularisation. D addresses training stability. None provide non-linearity.

Q3. ***Scenario:*** *A financial firm's deep learning UBA system generates an alert when an accounts payable employee downloads 3GB of vendor contracts on Sunday at 16:00. Investigation shows the employee had a Monday 08:00 deadline. The employee's normal access pattern shows downloads exclusively during weekday business hours.* An insider threat programme uses a deep learning UBA system that flags an employee who downloaded 3GB of files on a Sunday afternoon. Investigation finds the download is explained by a legitimate project deadline. What does this scenario BEST illustrate about deep learning UBA?

A. The model has insufficient training data to model this employee's behaviour

B. Deep learning UBA produces unacceptably high false-positive rates due to model complexity

C. The model correctly identified a deviation from the employee's baseline behaviour, and human judgment is required to determine whether the deviation is malicious

D. The model should be retrained immediately to include this event as normal

Answer: C **Explanation:** UBA models flag statistical deviations, not malicious intent. Flagging an unusual download is correct behaviour - the model cannot know whether the deviation has a legitimate explanation. Human investigation determines malicious versus benign. A assumes training data inadequacy without evidence. B overgeneralises from one false positive. D is premature.

Q4. What is the PRIMARY advantage of using an autoencoder for network traffic anomaly detection compared to a supervised deep learning classifier?

A. Autoencoders provide higher accuracy on known attack patterns because they are trained on labelled data

B. Autoencoders can detect novel attack types without requiring labelled examples of those attacks in training data

C. Autoencoders process traffic faster than supervised classifiers because they use fewer parameters

D. Autoencoders are more interpretable than supervised classifiers, simplifying alert triage

Answer: B **Explanation:** An autoencoder learns a compressed representation of normal traffic without labelled data. High reconstruction error indicates deviation from learned normal patterns, flagging anomalies including attack types the model has never seen. Supervised classifiers require labelled attack examples for each class. A is wrong - autoencoders are unsupervised. C is not generally true. D is wrong - autoencoders are equally or more opaque.

Q5. ***Scenario:*** *During a penetration test of an AI-powered IDS, the red team has API access but no access to model weights or architecture. They submit 2,000 modified network packet captures, observe classifier outputs, and iteratively refine modifications until the classifier misclassifies a known attack.* A red team tests a deep learning network traffic classifier by modifying attack traffic byte-by-byte via API and observing whether the classifier output shifts toward 'benign'. After 2,000 queries they craft a packet the classifier labels as benign. What type of attack has been conducted?

A. White-box adversarial attack using gradient information from the model weights

B. Black-box adversarial attack using query outputs to guide iterative perturbation

C. Data poisoning attack corrupting the classifier's training data

D. Transfer attack using a surrogate model to craft adversarial examples

Answer: B **Explanation:** A black-box adversarial attack uses only API query outputs (not model weights or gradients) to iteratively guide perturbation toward adversarial classification. A requires model weight/gradient access. C requires modifying training data. D requires a surrogate model, not described here.

Q6. An organisation uses a deep learning malware detector fine-tuned from a model trained predominantly on Windows PE file samples. They deploy it to analyse Linux ELF binaries after observing Linux server compromises. Detection rates are significantly lower than expected. What is the MOST likely cause?

A. The deep learning model requires GPU inference and the Linux servers use CPU-only hardware

B. Linux malware uses more sophisticated evasion techniques than Windows malware

C. The model learned representations specific to Windows PE file structure that do not generalise to Linux ELF binary format

D. The fine-tuning dataset was too small, causing the model to underfit all platforms equally

Answer: C **Explanation:** Fine-tuned models inherit learned representations of their base model. A model trained on Windows PE files learns PE header structures and Windows API call patterns that do not transfer to Linux ELF format with different headers and syscall interfaces. This is a domain shift problem. A is an infrastructure issue. B is speculative. D would affect Windows performance equally.

Q7. ***Scenario:*** *A bank's fraud detection team deploys a 50-million-parameter deep neural network achieving 97% fraud detection. The regulator issues guidance requiring 'explainable decision-making' for all automated account restrictions.* A financial services regulator requires that all automated decisions resulting in account restrictions be accompanied by a human-interpretable explanation. The firm's fraud detection uses a deep neural network with 50 million parameters. Which approach BEST addresses the regulatory requirement?

A. Replace the deep learning model with a decision tree that provides inherently interpretable rules

B. Apply SHAP or LIME to generate post-hoc feature importance explanations for individual predictions

C. Retrain the model with fewer parameters to reduce opacity until the model becomes interpretable

D. Disclose only the model's overall accuracy metrics to the regulator as evidence of reliability

Answer: B **Explanation:** SHAP and LIME generate per-prediction feature importance explanations satisfying regulatory interpretability requirements without sacrificing accuracy. A would require replacing the deep model and losing detection capability. C does not reliably produce interpretable models and degrades accuracy. D does not satisfy per-decision explanation requirements.

Q8. Operation AppleJeus demonstrates which property of deep learning malware detection that distinguishes it from signature-based approaches?

A. Deep learning detects malware faster because it uses parallel GPU computation

B. Deep learning can detect malware variants that share no code with training samples by learning higher-level behavioural patterns

C. Deep learning requires no training data because it uses rule-based reasoning about malware characteristics

D. Deep learning eliminates false positives because it has perfect precision on novel malware variants

Answer: B **Explanation:** Lazarus Group continuously mutated AppleJeus code while preserving functional behaviour. Signature-based AV failed on each variant. Deep learning models trained on API call sequences maintained detection because the behavioural signature remained consistent despite code-level evolution. A is about speed. C is factually wrong. D is wrong - deep learning has imperfect precision.

Q9. Which of the following scenarios BEST describes a data poisoning attack against a deep learning security model?

A. An attacker submits 10,000 API queries to a deployed model to craft an adversarial malware sample

B. An attacker contributes malware samples labelled as 'benign' to a public threat intelligence feed used to train the model

C. An attacker reverse-engineers the model architecture from API query responses

D. An attacker exploits a vulnerability in the model's serving infrastructure to exfiltrate model weights

Answer: B **Explanation:** Data poisoning corrupts training data. An attacker who can influence the training dataset by contributing mislabelled malware samples to a public feed can embed backdoors or reduce detection rates. A describes a black-box adversarial attack. C describes model architecture extraction. D describes a model theft/infrastructure attack.

Q10. A deep learning UEBA system flags a senior finance manager who bulk-emailed a compressed archive of financial spreadsheets to their personal Gmail account on a Friday before three-week leave. What should the security team do FIRST?

A. Immediately terminate the employee's access and escalate to HR and legal

B. Dismiss the alert - senior employees routinely email files to personal accounts for remote work

C. Investigate the alert by reviewing content, the employee's prior access patterns, and whether sending financial data externally complies with policy

D. Retrain the UEBA model to exclude senior finance managers from anomaly scoring

Answer: C **Explanation:** A UBA alert is a statistical flag, not evidence of malice. The correct first step is investigation: reviewing file contents (sensitivity), prior access patterns, and whether the action violates data handling policy. A is premature without investigation. B dismisses without investigation - a risk management failure. D removes a monitored population without justification.

Q11. A security team wants to implement deep learning-based phishing email detection but has only 500 labelled phishing examples. Which approach MOST effectively addresses the limited labelled data constraint?

A. Train a deep neural network from scratch on the 500 examples with data augmentation

B. Use a pre-trained language model (e.g., BERT) fine-tuned on the 500 labelled phishing examples

C. Use unsupervised clustering on the 500 examples and flag clusters with high average word count

D. Apply rule-based heuristics instead of deep learning, given insufficient data

Answer: B **Explanation:** Transfer learning with a pre-trained language model is the standard approach when labelled data is scarce. The pre-trained model has already learned rich language representations from billions of tokens. Fine-tuning on 500 examples adapts these for phishing classification with far fewer examples than training from scratch. A requires orders of magnitude more data. C is unsupervised and does not exploit the labels. D abandons deep learning prematurely.

Q12. What distinguishes deep learning from classical machine learning in the context of intrusion detection?

A. Deep learning requires more interpretable models to satisfy audit requirements

B. Deep learning performs automatic feature discovery from raw data; classical ML requires expert-defined feature engineering

C. Deep learning exclusively uses decision trees to classify network traffic

D. Classical ML handles larger datasets more effectively than deep learning

Answer: B **Explanation:** The defining distinction is representation learning versus feature engineering.

Classical ML (SVM, Random Forest) requires security experts to define which features the model should examine. Deep learning discovers relevant features automatically from raw data. A reverses the interpretability relationship. C is incorrect. D is incorrect - deep learning scales better to large datasets.

Q13. An attacker modifies a malware binary by appending 50,000 random bytes to its end. A deep learning classifier analysing raw PE file bytes misclassifies the modified file as benign. What attack technique is this and what is the most appropriate defence?

A. Data poisoning; retrain the model with clean data

B. Adversarial example crafted to shift the model's representation; defend with adversarial training on similar perturbations

C. Training data extraction; apply differential privacy to model outputs

D. Transfer attack; deploy a diverse ensemble of models

Answer: B **Explanation:** Appending non-executable bytes is an established adversarial technique against byte-level malware classifiers. The bytes shift the model's representation toward the benign region. This is an adversarial example. The appropriate defence is adversarial training - retraining the model on examples of this perturbation type. A is wrong - training data is not corrupted. C is wrong - this is not a data extraction attack. D (ensemble) may help but adversarial training directly addresses the specific attack.

Q14. The Capital One breach investigation highlighted which gap in traditional monitoring that deep learning UBA would address?

A. Failure to patch known WAF vulnerabilities within the required maintenance window

B. Failure to detect unusual API call patterns (high-volume S3 GetObject from anomalous source) that deviated from established behavioural baselines

C. Failure to encrypt data at rest, allowing the attacker to read extracted files without decryption keys

D. Failure to enforce multi-factor authentication on the compromised AWS credentials

Answer: B **Explanation:** The attacker's S3 exfiltration pattern - high-volume GetObject calls from a source IP that had never previously accessed those resources at an unusual time - was a strong behavioural anomaly that static threshold monitoring did not catch. Deep learning UBA trained on normal cloud API access patterns would have flagged the deviation. A, C, and D identify other important controls but are not specifically about the behavioural anomaly detection gap.

Q15. A security AI team evaluates whether to use a CNN or an LSTM for detecting anomalous patterns in network packet sequences. The primary threat is multi-stage C2 communication using variable timing intervals across hundreds of connections. Which architecture is MOST appropriate?

A. CNN, because it can extract local byte patterns from individual packets more efficiently

B. LSTM, because it maintains temporal state across sequences and can model variable-length dependencies in connection timing patterns

C. CNN, because it handles sequences of arbitrary length better through pooling operations

D. LSTM, because it requires no labelled training data and learns normal traffic patterns unsupervised

Answer: B **Explanation:** LSTM networks maintain a cell state persisting across sequence steps, enabling them to model temporal dependencies across variable-length sequences - ideal for C2 timing patterns spanning many connections over time. CNN excels at local feature extraction in fixed-size windows but lacks ability to model long temporal dependencies. C is wrong - CNNs with pooling don't capture long temporal dependencies. D is wrong - LSTMs are supervised architectures.

Q16. What is the PRIMARY security risk of deploying an open-source pre-trained deep learning model from a public model repository for enterprise security applications?

A. Open-source models have lower accuracy than commercially developed models

B. Open-source models may contain backdoors embedded via data poisoning during pre-training, activatable by specific trigger inputs

C. Open-source models cannot be fine-tuned on proprietary data without rebuilding from scratch

D. Open-source models lack GPU support and will be too slow for production security workloads

Answer: B **Explanation:** The primary AI supply chain risk is backdoored pre-trained models. An attacker who contributes a poisoned model to a public hub can embed backdoors that activate on trigger inputs while maintaining normal performance on clean inputs. This is analogous to supply chain attacks on open-source software packages. A is not generally true. C is wrong - fine-tuning is standard practice. D is wrong - most public models are GPU-compatible.

Q17. An AI security analyst uses SHAP to explain a deep learning fraud classifier's prediction that a transaction is fraudulent. SHAP assigns high positive values to 'transaction_amount', 'time_of_day', and 'merchant_category'. What does this BEST indicate?

A. The model has overfit to these three features and will fail to generalise

B. These three features contributed most strongly to the fraudulent classification for this specific transaction

C. The model has determined these features are the only signals relevant to fraud detection globally

D. The analyst should remove these features to prevent the model from being fooled by manipulating them

Answer: B **Explanation:** SHAP generates per-prediction, local feature importance explanations. A high SHAP value means that feature pushed the model toward 'fraudulent' for this specific input. SHAP values are local and instance-specific, not global. A (overfitting) cannot be inferred from a single SHAP explanation. C mischaracterises SHAP's local scope. D is an inappropriate action based on misinterpretation.

Q18. A cybersecurity team building a deep learning insider threat system from email metadata must address which GREATEST risk during system design?

A. The model may require too much GPU memory to process email metadata at scale

B. Email metadata alone may not capture enough signal to detect sophisticated insiders using personal devices

C. The system may constitute unlawful employee monitoring without proper legal basis, notice, and data minimisation controls

D. Email metadata is too structured for deep learning, which is best suited to unstructured data types

Answer: C **Explanation:** Processing employee email metadata for monitoring purposes is a data protection-regulated activity. Without a lawful basis, appropriate employee notice, purpose limitation, and data minimisation controls, the organisation risks violating GDPR, CCPA, or sector-specific regulations. This legal and ethical risk is the greatest. B is a detection coverage concern. A is an infrastructure concern. D is factually wrong.

Q19. What is the correct relationship between deep learning, machine learning, and artificial intelligence?

A. Deep learning and machine learning are interchangeable terms; artificial intelligence is a broader category

B. Artificial intelligence is a subset of machine learning, which is a subset of deep learning

C. Deep learning is a subset of machine learning, which is a subset of artificial intelligence

D. Machine learning and deep learning are independent fields that both contribute to artificial intelligence

Answer: C **Explanation:** The correct hierarchy is: AI (broadest - any system exhibiting intelligent behaviour) includes ML (systems that learn from data) which includes Deep Learning (ML using multi-layer neural networks). A (interchangeable terms) is wrong. B inverts the hierarchy. D (independent fields) is wrong - deep learning is a specific type of machine learning.

Q20. A security team discovers their deep learning IDS consistently fails to detect attacks when the attacker uses encrypted C2 traffic over HTTPS. The model was trained exclusively on unencrypted traffic. Which approach BEST addresses this limitation?

A. Retrain the model on decrypted traffic only by deploying TLS inspection

B. Supplement the deep learning model with encrypted traffic analysis techniques based on metadata features (packet timing, size distributions, flow duration, TLS fingerprints)

C. Replace the deep learning model with a signature-based IDS effective against encrypted traffic

D. Accept the limitation - it is impossible for any AI system to detect threats in encrypted traffic

Answer: B **Explanation:** Encrypted traffic cannot be inspected at the payload level without TLS interception. However, encrypted traffic has metadata characteristics (packet timing, size distributions, JA3/JA3S TLS fingerprints, byte entropy) that deep learning models can analyse. Retraining on these features enables detection without decryption. A introduces significant legal and privacy concerns. C is equally limited. D is wrong - metadata-based detection is effective.